

Universidad
Manuela Beltrán
Acreditada en Alta Calidad Multicampus

GastoTransparente Municipal

Cobos, Dilan Steven

Rodríguez Ángel, Santiago

Alarcón Ospina, Víctor Alfonso

Universidad Manuela Beltrán

Ingeniería de Software

Facultad de Ingeniería

Desarrollo de Software Seguro

Docente: Hernan Dario Cruz

Bogotá, Colombia

2026

1. Contexto del Proyecto

GastoTransparente Municipal es una plataforma web de transparencia para el seguimiento del gasto público municipal, alineada con el ODS 16 (Paz, Justicia e Instituciones Sólidas). Permite a ciudadanos, auditores y funcionarios consultar, publicar y fiscalizar contratos y ejecuciones presupuestales de manera abierta y verificable.

1.1 Descripción del Sistema

La plataforma gestiona contratos públicos municipales con control de versiones, firmas digitales y logs inmutables. Expone una API REST pública con autenticación JWT y un portal web. El contexto político es crítico: cualquier indisponibilidad o manipulación de datos durante períodos electorales tiene consecuencias institucionales directas.

1.2 Actores del Sistema

Tabla 1
Actores del sistema y contexto de riesgo

Rol	Permisos	Contexto de riesgo
Ciudadano	Lectura de contratos y reportes públicos.	Vector de scraping, IDOR y exfiltración encubierta.
Editor	Crear y modificar contratos dentro de su municipio.	Amenaza interna de mayor riesgo directo.
Auditor	Revisar, aprobar y rechazar contratos.	Objetivo principal de phishing y fuerza bruta.
Administrador	Gestión total: usuarios, configuración e informes.	Compromiso crítico si se escala privilegios (CA-11).

Nota. Elaboración propia.

2. Requisitos de Seguridad (RS-01 a RS-13)

Se definen 13 requisitos de seguridad alineados con la tríada CIA y OWASP. **Los tres últimos (RS-11 a RS-13) surgen del stress test y cubren vectores avanzados.**

Tabla 2
Requisitos de seguridad RS-01 a RS-13

ID	Tipo	Requisito	Descripción	Justificación de seguridad
RS-01	**Funcional**	Autenticación Multifactor (MFA)	MFA (TOTP/FIDO2) obligatorio para Editor, Auditor y Admin.	Previene accesos con credenciales comprometidas por phishing o fuerza bruta.
RS-02	**No Funcional**	Cifrado AES-256 / TLS 1.3	Datos en reposo con AES-256; tránsito con TLS 1.3.	Confidencialidad e integridad ante accesos no autorizados a la infraestructura.
RS-03	**Funcional**	Log de Auditoría Inmutable (Append-Only)	Cada cambio genera entrada append-only firmada; nadie puede borrarla.	Trazabilidad completa y detección de manipulaciones de datos públicos.
RS-04	**No Funcional**	Anti-DDoS y Rate Limiting	CDN con scrubbing DDoS; rate limiting por IP/token; soporta 50 000 req/min.	El sistema es políticamente sensible; un DDoS electoral silencia la rendición de cuentas.
RS-05	**Funcional**	RBAC (Control de Acceso por Roles)	Ciudadano (lectura), Editor (escritura limitada), Auditor (revisión), Admin (total).	Limita el radio de acción de credenciales comprometidas.
RS-06	**Funcional**	Firma Digital de Registros	Cada registro publicado incluye firma del funcionario, verificable por ciudadanos.	Garantiza autenticidad; cualquier alteración invalida la firma.
RS-07	**No Funcional**	Expiración de Sesión por Inactividad	Privilegiados: 10 min; ciudadanos: 30 min.	Reduce ventana de explotación en equipos compartidos.
RS-08	**Funcional**	Validación y Sanitización de Entradas	Whitelist en todos los campos; sanitización contra SQLi, XSS, Path Traversal.	Bloquea las técnicas de inyección del OWASP Top 10.
RS-09	**No Funcional**	Política de Contraseñas y Bloqueo	Mín. 12 caracteres; bloqueo tras 5 intentos; notificación por e-mail.	Mitiga fuerza bruta y credential stuffing.

ID	Tipo	Requisito	Descripción	Justificación de seguridad
RS-10	**Funcional**	**Alertas SIEM en Tiempo Real**	Alerta <60 s ante accesos fuera de horario, descargas masivas o cambios inusuales.	Reduce MTTD ante incidentes.
RS-11	**Funcional**	**Validación Estricta de JWT — Algoritmo Fijo**	jwt.verify() con { algorithms:['HS256'] } en todos los endpoints. Se prohíbe jwt.decode(). HTTP 401 ante alg:'none' o algorithm confusion.	Cierra CA-11: RS-05 solo es efectivo con validación correcta del token.
RS-12	**Funcional**	**Atomicidad y Locks en Aprobación Multi-firma**	SELECT FOR UPDATE en la fila del contrato; idempotency key por aprobación; verificación de IDs distintos en BD antes del commit.	Previene race conditions en doble firma (CA-12); sin esto RS-03/RS-06 registran el fraude pero no lo impiden.
RS-13	**No Funcional**	**Correlación Multi-Vector SIEM con Baseline**	Correlación por token en ventanas de 30 min; alerta si >10 documentos únicos/hora; borradores solo para Auditor/Admin.	Detecta ataques bajo el umbral individual de cada señal (CA-13).

Nota. Los requisitos RS-11 a RS-13 surgen del stress test. Elaboración propia.

3. Casos de Abuso (CA-01 a CA-13)

13 casos de abuso modelados desde la perspectiva del atacante. **Los casos CA-11 a CA-13 (marcados con ★) fueron identificados en el stress test.**

Tabla 3
CA-01 — Manipulación de Registros por Funcionario Interno

Riesgo: CRÍTICO | Probabilidad: Alta | Impacto: Alto	
Atacante	Funcionario municipal con rol Editor.
Objetivo	Alterar montos de contratos para ocultar desviación de fondos.
Acciones del atacante	1. Inicia sesión con credenciales legítimas. 2. Edita registros cambiando montos y beneficiarios. 3. Intenta borrar historial de cambios.
Impacto	**Pérdida de integridad de datos públicos; encubrimiento de corrupción.**
Mitigaciones	✓ Log append-only con firma digital; nadie puede borrar entradas. ✓ Workflow de aprobación dual para contratos > umbral. ✓ Alertas al supervisor ante modificación fuera de rango estadístico.

Nota. Elaboración propia.

Tabla 4
CA-02 — DDoS durante Rendición de Cuentas Electoral

Riesgo: CRÍTICO | Probabilidad: Alta | Impacto: Alto	
Atacante	Grupo político adversario con acceso a botnet.
Objetivo	Silenciar la plataforma en período electoral.
Acciones del atacante	1. Coordina botnet para saturar el portal. 2. Satura endpoints de búsqueda y descarga. 3. Usa IPs rotativas para evadir bloqueos.
Impacto	**Indisponibilidad en período crítico; daño a la confianza pública.**
Mitigaciones	✓ CDN con protección DDoS (Cloudflare / AWS Shield Advanced). ✓ Rate limiting por IP, token y geolocalización. ✓ Auto-scaling y arquitectura serverless.

Nota. Elaboración propia.

Tabla 5
CA-03 — Inyección SQL en Buscador de Contratos

Riesgo: ALTO | Probabilidad: Media | Impacto: Alto	
Atacante	Atacante externo con conocimiento técnico.
Objetivo	Extraer datos o eliminar registros históricos.
Acciones del atacante	1. Ingresa payloads SQL: ' OR '1'='1'-- 2. UNION SELECT para extraer tablas internas. 3. Intenta DROP TABLE para destruir historial.
Impacto	**Exposición de datos internos; destrucción de registros históricos.**
Mitigaciones	✓ ORM con consultas parametrizadas; prohibir SQL dinámico. ✓ WAF con reglas OWASP Core Rule Set. ✓ Mínimo privilegio en BD: solo SELECT/INSERT en tablas necesarias.

Nota. Elaboración propia.

Tabla 6
CA-04 — XSS Persistente en Panel de Comentarios

Riesgo: ALTO | Probabilidad: Media | Impacto: Alto	
Atacante	Ciudadano malintencionado o actor político con cuenta básica.
Objetivo	Robar sesiones de administradores o inyectar desinformación.
Acciones del atacante	1. Publica comentario con script malicioso. 2. El script se ejecuta cuando un Admin lo visualiza. 3. Exfiltra token de sesión del Admin.
Impacto	**Toma de control de cuenta Admin; desinformación masiva; posible defacement.**
Mitigaciones	✓ Sanitización HTML con DOMPurify + CSP estricta. ✓ Tokens de sesión con flags HttpOnly y Secure. ✓ Moderación de comentarios antes de publicación.

Nota. Elaboración propia.

Tabla 7
CA-05 — Suplantación de Funcionario (Phishing)

Riesgo: CRÍTICO | Probabilidad: Alta | Impacto: Alto	
Atacante	Atacante externo que compromete correo corporativo.
Objetivo	Publicar datos falsos como funcionario autorizado.
Acciones del atacante	1. Spear-phishing al funcionario para robar credenciales. 2. Accede al panel desde IP diferente. 3. Publica contratos falsos o altera montos.
Impacto	**Datos falsos publicados como oficiales; pérdida de credibilidad institucional.**
Mitigaciones	✓ MFA obligatorio: credenciales robadas no bastan. ✓ Análisis de comportamiento: IP inusual activa bloqueo. ✓ Capacitación anti-phishing y simulacros periódicos.

Nota. Elaboración propia.

Tabla 8
CA-06 — Acceso No Autorizado a Reportes (IDOR)

Riesgo: ALTO | Probabilidad: Media | Impacto: Medio	
Atacante	Ciudadano, periodista o actor con acceso básico.
Objetivo	Acceder a informes de auditoría internos antes de publicación.
Acciones del atacante	1. Observa URL: /reportes/2026/informe_123.pdf 2. Modifica ID: /reportes/2026/informe_001.pdf 3. Itera IDs con script automatizado.
Impacto	**Filtración de datos de auditoría preliminares; uso político de información sin contexto.**
Mitigaciones	✓ UUIDs no predecibles para todos los recursos. ✓ Verificación explícita de permisos en cada solicitud. ✓ Logs de acceso con alertas ante iteración.

Nota. Elaboración propia.

Tabla 9
CA-07 — Fuerza Bruta sobre Cuentas de Auditores

Riesgo: ALTO | Probabilidad: Alta | Impacto: Alto	
Atacante	Atacante automatizado con lista de credenciales filtradas.
Objetivo	Obtener acceso privilegiado por diccionario o credential stuffing.
Acciones del atacante	1. Descarga listas de contraseñas comunes. 2. Ataca el endpoint de login con miles de combinaciones. 3. Prueba credential stuffing con brechas de otras plataformas.
Impacto	**Compromiso de cuenta de auditor; acceso a datos internos no publicados.**
Mitigaciones	✓ Bloqueo temporal tras 5 intentos; desbloqueo con CAPTCHA. ✓ Notificación al usuario ante intentos repetidos. ✓ MFA como segunda barrera.

Nota. Elaboración propia.

Tabla 10
CA-08 — Defacement del Portal Público

Riesgo: ALTO | Probabilidad: Media | Impacto: Alto	
Atacante	Hacktivista o grupo de presión política.
Objetivo	Alterar la apariencia del portal para difundir desinformación.
Acciones del atacante	1. Explota vulnerabilidad en dependencia desactualizada. 2. Reemplaza página principal con contenido falso. 3. Deja mensaje o malware para visitantes.
Impacto	**Daño reputacional severo; posible infección de equipos de ciudadanos.**
Mitigaciones	✓ WAF + IDS/IPS con detección de modificación de archivos. ✓ Monitoreo de integridad de archivos (AIDE/Tripwire). ✓ Pipeline CI/CD con despliegues inmutables.

Nota. Elaboración propia.

Tabla 11
CA-09 — Exfiltración Masiva de Datos vía API sin Restricción

Riesgo: MEDIO | Probabilidad: Alta | Impacto: Medio	
Atacante	Competidor o actor con token de API legítimo.
Objetivo	Descargar toda la BD de contratos para análisis privado.
Acciones del atacante	1. Obtiene token de API ciudadano. 2. Itera /api/contratos?page=1..N sin restricción de volumen. 3. Exporta BD completa en pocas horas.
Impacto	**Uso comercial no autorizado; sobrecarga del servidor.**
Mitigaciones	✓ Rate limiting: máx. 100 req/min con HTTP 429 al excederlo. ✓ Paginación obligatoria con límite de 100 registros por página. ✓ Suspensión automática ante abuso.

Nota. Elaboración propia.

Tabla 12
CA-10 — Carga de Documentos Maliciosos (Malware Upload)

Riesgo: ALTO | Probabilidad: Baja | Impacto: Alto	
Atacante	Funcionario comprometido o atacante con acceso de editor.
Objetivo	Alojar malware bajo apariencia de documentos oficiales.
Acciones del atacante	1. Sube PDF con JavaScript embebido o DOCX con macro maliciosa. 2. El archivo queda publicado como 'Informe Oficial'. 3. Ciudadanos descargan el archivo e infectan sus equipos.
Impacto	**Infección masiva de dispositivos; daño reputacional; responsabilidad legal.**
Mitigaciones	✓ Análisis antivirus en tiempo real (ClamAV / VirusTotal API). ✓ Lista blanca de extensiones con validación MIME real. ✓ Sandbox antes de publicación definitiva.

Nota. Elaboración propia.

Tabla 13

CA-11 — Escalada de Privilegios por Manipulación de JWT (Algorithm Confusion) ★ NUEVO

Riesgo: CRÍTICO | Probabilidad: Alta | Impacto: Alto	
Atacante	Ciudadano técnico con cuenta registrada y conocimiento de criptografía JWT.
Objetivo	Elevar privilegios de Ciudadano a Administrador sin credenciales válidas de alto nivel.
Acciones del atacante	1. Se autentica como ciudadano y captura el JWT con Burp Suite Proxy. 2. Decodifica el payload: {"sub":"123","role":"citizen"} — el rol está en el payload sin binding a dispositivo. 3. Intenta "algorithm confusion": cambia alg de RS256 a HS256 usando la clave pública como secreto HMAC. 4. Modifica payload: "role":"citizen" → "role":"admin". Regenera token con el nuevo algoritmo. 5. Si el servidor usa jwt.decode() en lugar de jwt.verify(), acepta el token sin validar firma. 6. Con acceso Admin extrae lista de auditores → base para phishing dirigido (CA-05).
Impacto	**Compromiso total del RBAC. Un ciudadano opera como Admin: modifica contratos públicos, crea cuentas y prepara ataques de phishing dirigidos.**
Gap identificado	**RS-05 define roles RBAC correctamente, pero no especifica que la validación del JWT debe hacerse con jwt.verify(). La diferencia entre jwt.decode() (sin verificar firma) y jwt.verify() (firma + algoritmo fijo) es el vector exacto.**
Mitigaciones	✓ jwt.verify() con { algorithms:['HS256'] } obligatorio — rechaza alg:'none' y confusion attacks. [RS-11] ✓ Verificar rol en BD en cada endpoint, nunca solo en el token. [RS-11] ✓ JWT secrets ≥256 bits, rotación 90 días, expiración máx. 30 min. [RS-11] ✓ Auditoría inmediata ante acceso Admin con token de rol inferior. [RS-10 + RS-11]
Requisito de seguridad generado: RS-11	

Nota. Caso identificado durante el stress test. Elaboración propia.

Tabla 14

CA-12 — Race Condition en Aprobación Dual de Contratos (Business Logic Manipulation) ★ NUEVO

Riesgo: ALTO | Probabilidad: Media | Impacto: Alto	
Atacante	Funcionario Editor con herramientas de automatización básica.
Objetivo	Aprobar contrato fraudulento con una sola firma burlando el workflow de doble aprobación.
Acciones del atacante	1. Edita contrato: cambia monto de $100M a $175M. 2. Envía solicitud al workflow de aprobación dual (requiere Auditor A y Auditor B). 3. Lanza 50 requests concurrentes al endpoint POST /api/contratos/{id}/aprobar con su token. 4. La race condition permite dos 'aprobaciones' del mismo firmante antes de verificar unicidad. 5. El contrato queda APROBADO; el log registra dos timestamps casi idénticos del mismo usuario.
Impacto	**Contrato de $175M aprobado con proceso aparentemente válido. RS-03 registra el fraude pero no lo previene; RS-06 existe pero es del mismo actor duplicado por concurrencia.**
Gap identificado	**RS-03 y RS-06 cubren integridad y trazabilidad, pero ninguno especifica atomicidad transaccional ni control de concurrencia en el flujo de aprobación. El log registra pero no bloquea.**
Mitigaciones	✓ SELECT FOR UPDATE en la fila del contrato durante aprobación. [RS-12] ✓ Idempotency key por aprobación: token único de un solo uso, HTTP 409 ante duplicados. [RS-12] ✓ Verificación en BD de IDs distintos antes del commit final. [RS-12] ✓ Alerta SIEM ante dos aprobaciones del mismo contrato en < 5 segundos. [RS-10 + RS-12]
Requisito de seguridad generado: RS-12	

Nota. Caso identificado durante el stress test. Elaboración propia.

Tabla 15
CA-13 — Exfiltración Encubierta Multi-Vector (IDOR + API Scraping Correlacionado) ★ NUEVO

Riesgo: ALTO | Probabilidad: Alta | Impacto: Alto	
Atacante	Periodista técnico con token ciudadano y scripts Python.
Objetivo	Descargar informes internos no publicados para obtener ventaja política antes de su publicación oficial.
Acciones del atacante	1. Obtiene token ciudadano legítimo; enumera IDs en /api/reportes. 2. Descubre que /api/reportes?estado=borrador no verifica el rol del solicitante. 3. Descarga 1–3 reportes por minuto (bajo el umbral de RS-04) alternando endpoints. 4. Combina datos internos con datos públicos para identificar contratos bajo revisión. 5. Toda la actividad aparece legítima en el SIEM: ciudadano accediendo a documentos normalmente.
Impacto	**Filtración de auditorías pre-publicación sin disparar ninguna alerta. CA-06 + CA-09 combinados son invisibles; el atacante obtiene ventaja informativa política antes que el público.**
Gap identificado	**CA-06 y CA-09 se modelaron como amenazas independientes. El SIEM (RS-10) monitorea señales individuales pero no correlaciona multi-vector. Un atacante bajo cada umbral individual no es detectado.**
Mitigaciones	✓ Control de acceso por estado: borradores solo para Auditor/Admin. [RS-13] ✓ Correlación multi-vector SIEM: mismo token, múltiples endpoints sensibles en 30 min. [RS-13] ✓ Baseline: alerta si token ciudadano accede a >10 documentos únicos/hora. [RS-13] ✓ Auditoría diferenciada: público vs. en revisión interna. [RS-13]
Requisito de seguridad generado: RS-13	

Nota. Caso identificado durante el stress test. Elaboración propia.

4. Matriz de Riesgo — OWASP Risk Rating

Score = Likelihood (L) × Impact (I), escala 1–5. Score ≥ 12 = CRÍTICO. Casos ★ son nuevos del stress test.

Tabla 16
Matriz de riesgo de los casos de abuso según OWASP Risk Rating

ID	Caso de Abuso	L	I	Score	Nivel de Riesgo	Requisito que lo cubre
CA-01	Manipulación de registros	**3**	**4**	**12**	**CRÍTICO**	RS-03, RS-06, RS-10
CA-02	DDoS electoral	**3**	**5**	**15**	**CRÍTICO**	RS-04
CA-03	SQL Injection	**2**	**4**	**8**	**ALTO**	RS-08
CA-04	XSS en comentarios	**2**	**3**	**6**	**ALTO**	RS-08, RS-07
CA-05	Phishing de funcionario	**3**	**4**	**12**	**CRÍTICO**	RS-01, RS-09
CA-06	IDOR en reportes	**3**	**3**	**9**	**ALTO**	RS-05, RS-08
CA-07	Fuerza bruta sobre auditores	**3**	**3**	**9**	**ALTO**	RS-09, RS-01
CA-08	Defacement del portal	**1**	**4**	**4**	**ALTO**	RS-08, RS-10
CA-09	Exfiltración masiva vía API	**3**	**2**	**6**	**MEDIO**	RS-04
CA-10	Carga de documentos maliciosos	**1**	**4**	**4**	**ALTO**	RS-08
CA-11 ★	**Escalada de privilegios JWT ★**	**3**	**5**	**15**	**CRÍTICO**	RS-11 (nuevo)
CA-12 ★	**Race condition aprobación dual ★**	**2**	**4**	**8**	**ALTO**	RS-12 (nuevo)
CA-13 ★	**Exfiltración multi-vector ★**	**3**	**4**	**12**	**CRÍTICO**	RS-13 (nuevo)

Nota. Score = Likelihood × Impact, en escala de 1 a 5; un score ≥ 12 se clasifica como crítico. El símbolo ★ identifica los casos hallados en el stress test. Elaboración propia.

5. Identificación del Anti-Personaje

El anti-personaje es el perfil detallado del atacante específico para el sector. GastoTransparente opera en un contexto de alta sensibilidad política, lo que define atacantes con motivaciones distintas a las de un sistema empresarial convencional.

Tabla 17
"El Concejal" — Amenaza Interna

Atributo	Descripción
Perfil del atacante	Funcionario municipal con rol Editor, 3 años en el cargo, conocimiento básico de sistemas web.
Motivación	Desviar fondos de contratos de infraestructura sin dejar rastro auditable en el log.
Acceso inicial	Credenciales legítimas de Editor — no necesita hackear nada para entrar.
Horario operativo	Horario laboral normal (08:00–18:00) para evitar alertas del SIEM.
Nivel técnico	Bajo — usa exclusivamente la interfaz web.
Impacto potencial	**CRÍTICO — Corrupción directa de datos públicos desde adentro del sistema.**

Nota. Elaboración propia.

Tabla 18
"La Botnet Electoral" — Amenaza Externa Coordinada

Atributo	Descripción
Perfil del atacante	Grupo político adversario con acceso a botnet de 500–2000 nodos distribuidos globalmente.
Motivación	Silenciar la plataforma durante el período de rendición de cuentas electoral.
Acceso inicial	Sin acceso al sistema — ataca exclusivamente los endpoints públicos desde internet.
Horario operativo	Picos en horario de máxima audiencia (19:00–22:00) y durante debates transmitidos.
Nivel técnico	Alto — operación coordinada con C2 centralizado, IPs rotativas, proxies y amplificación DNS.
Impacto potencial	**CRÍTICO — Indisponibilidad en el momento político de mayor visibilidad ciudadana.**

Nota. Elaboración propia.

Tabla 19
"El API Hunter" — Amenaza Gris (Insider Pasivo)

Atributo	Descripción
Perfil del atacante	Periodista de datos o consultor político con cuenta de Ciudadano y conocimiento técnico avanzado.
Motivación	Acceder a informes de auditoría internos antes de su publicación oficial.
Acceso inicial	Token de API de ciudadano obtenido por registro público y legítimo en la plataforma.
Horario operativo	Actividad en ventanas de 30–60 min en horarios variados para evadir el SIEM.
Nivel técnico	Alto — combina IDOR, enumeración de IDs y scraping automatizado con Python.
Impacto potencial	**ALTO — Filtración de datos internos; uso político de información sin contexto oficial.**

Nota. Elaboración propia.

6. Diagrama de Casos de Abuso

El diagrama muestra cómo cada actor malicioso explota los puntos de entrada del sistema. Los **flujos de ataque** contrastan con los **flujos legítimos** para evidenciar cómo la misma funcionalidad se convierte en vector de ataque.

6.1 Relación Actor — Punto de Entrada — Caso de Abuso

Tabla 20
Relación entre actor malicioso, punto de entrada y caso de abuso

Actor malicioso	Punto de entrada	Superficie / Endpoint	Caso de abuso
El API Hunter	Autenticación / JWT	POST /api/auth/login Authorization: Bearer	**CA-07 Fuerza bruta CA-11 ★ Algorithm Confusion**
El Concejal	Workflow de aprobación	POST /api/contratos/{id}/aprobar	**CA-01 Manipulación interna CA-12 ★ Race Condition**
El API Hunter	API pública de reportes	GET /api/reportes?estado=...	**CA-06 IDOR CA-09 Exfiltración CA-13 ★ Multi-vector**

Actor malicioso	Punto de entrada	Superficie / Endpoint	Caso de abuso
Actor político	Panel de comentarios	POST /api/comentarios	**CA-04 XSS persistente**
La Botnet Electoral	Portal HTTP público	Todos los endpoints GET públicos	**CA-02 DDoS electoral**
Atacante externo	Buscador de contratos	GET /api/contratos?q=...	**CA-03 SQL Injection**
Funcionario comprometido	Carga de archivos	POST /api/documentos/upload	**CA-10 Malware Upload**
Atacante ext. / actor	Login / Sesiones	POST /api/auth/login + tokens JWT	**CA-05 Phishing CA-08 Defacement**

Nota. Elaboración propia.

6.2 User Story vs. Abuse Story — Comparativa

Cada par expone cómo la misma funcionalidad sirve de vector de ataque cuando el actor tiene intenciones maliciosas.

Tabla 21
Comparativa entre user story y abuse story

Funcionalidad	User Story (flujo legítimo)	Abuse Story (flujo de ataque)	Actor
Autenticación y JWT	Como funcionario, inicio sesión con mis credenciales para acceder al panel de edición de contratos.	Como API Hunter, capturo mi JWT de ciudadano, cambio "role" a "admin" y lo reenvío sin verificar firma — accedo al panel de administración (CA-11).	**El API Hunter**
Aprobación de contratos	Como editor, envío el contrato al workflow de doble aprobación que requiere las firmas de dos auditores distintos.	Como Concejal, envío 50 requests concurrentes con mi token para que el servidor registre el contrato como aprobado con una sola firma (CA-12).	**El Concejal**

Funcionalidad	User Story (flujo legítimo)	Abuse Story (flujo de ataque)	Actor
Consulta de reportes públicos	Como ciudadano, consulto los reportes de ejecución presupuestal publicados oficialmente por el municipio.	Como API Hunter, combino IDOR + scraping a ritmo bajo para descargar borradores internos sin superar el umbral de rate-limit ni activar el SIEM (CA-13).	**El API Hunter**
Panel de comentarios ciudadanos	Como ciudadano, publico un comentario sobre la ejecución del presupuesto para fiscalizar el gasto público.	Como actor político, inyecto un script XSS en el comentario. Cuando un Admin lo visualiza, el script exfiltra su token de sesión (CA-04).	**Actor político**
Disponibilidad del portal	Como ciudadano, accedo al portal en cualquier momento para verificar el presupuesto en tiempo real.	Como Botnet Electoral, saturo el portal durante el debate público para silenciar la rendición de cuentas en el momento de mayor visibilidad (CA-02).	**La Botnet Electoral**

Nota. Elaboración propia.

7. Nuevos Casos de Abuso Identificados (CA-11, CA-12, CA-13)

El stress test identificó tres vectores no contemplados en el modelo original (CA-01 a CA-10): **Privilege Escalation (CA-11)**, **Business Logic Manipulation (CA-12)** y **Exfiltración Multi-Vector (CA-13)**. Cada uno genera un nuevo requisito de seguridad.

Tabla 22

CA-11 — Escalada de Privilegios por Manipulación de JWT (Algorithm Confusion) ★ NUEVO

Riesgo: CRÍTICO | Probabilidad: Alta | Impacto: Alto	
Atacante	Ciudadano técnico con cuenta registrada y conocimiento de criptografía JWT.
Objetivo	Elevar privilegios de Ciudadano a Administrador sin credenciales válidas de alto nivel.
Acciones del atacante	1. Se autentica como ciudadano y captura el JWT con Burp Suite Proxy. 2. Decodifica el payload: {"sub":"123","role":"citizen"} — el rol está en el payload sin binding a dispositivo. 3. Intenta "algorithm confusion": cambia alg de RS256 a HS256 usando la clave pública como secreto HMAC. 4. Modifica payload: "role":"citizen" → "role":"admin". Regenera token con el nuevo algoritmo. 5. Si el servidor usa jwt.decode() en lugar de jwt.verify(), acepta el token sin validar firma. 6. Con acceso Admin extrae lista de auditores → base para phishing dirigido (CA-05).
Impacto	**Compromiso total del RBAC. Un ciudadano opera como Admin: modifica contratos públicos, crea cuentas y prepara ataques de phishing dirigidos.**
Gap identificado	**RS-05 define roles RBAC correctamente, pero no especifica que la validación del JWT debe hacerse con jwt.verify(). La diferencia entre jwt.decode() (sin verificar firma) y jwt.verify() (firma + algoritmo fijo) es el vector exacto.**
Mitigaciones	✓ jwt.verify() con { algorithms:['HS256'] } obligatorio — rechaza alg:'none' y confusion attacks. [RS-11] ✓ Verificar rol en BD en cada endpoint, nunca solo en el token. [RS-11] ✓ JWT secrets ≥256 bits, rotación 90 días, expiración máx. 30 min. [RS-11] ✓ Auditoría inmediata ante acceso Admin con token de rol inferior. [RS-10 + RS-11]
Requisito de seguridad generado: RS-11	

Nota. Caso identificado durante el stress test. Elaboración propia.

Tabla 23
CA-12 — Race Condition en Aprobación Dual de Contratos (Business Logic Manipulation) ★ NUEVO

Riesgo: ALTO | Probabilidad: Media | Impacto: Alto	
Atacante	Funcionario Editor con herramientas de automatización básica.
Objetivo	Aprobar contrato fraudulento con una sola firma burlando el workflow de doble aprobación.
Acciones del atacante	1. Edita contrato: cambia monto de $100M a $175M. 2. Envía solicitud al workflow de aprobación dual (requiere Auditor A y Auditor B). 3. Lanza 50 requests concurrentes al endpoint POST /api/contratos/{id}/aprobar con su token. 4. La race condition permite dos 'aprobaciones' del mismo firmante antes de verificar unicidad. 5. El contrato queda APROBADO; el log registra dos timestamps casi idénticos del mismo usuario.
Impacto	**Contrato de $175M aprobado con proceso aparentemente válido. RS-03 registra el fraude pero no lo previene; RS-06 existe pero es del mismo actor duplicado por concurrencia.**
Gap identificado	**RS-03 y RS-06 cubren integridad y trazabilidad, pero ninguno especifica atomicidad transaccional ni control de concurrencia en el flujo de aprobación. El log registra pero no bloquea.**
Mitigaciones	✓ SELECT FOR UPDATE en la fila del contrato durante aprobación. [RS-12] ✓ Idempotency key por aprobación: token único de un solo uso, HTTP 409 ante duplicados. [RS-12] ✓ Verificación en BD de IDs distintos antes del commit final. [RS-12] ✓ Alerta SIEM ante dos aprobaciones del mismo contrato en < 5 segundos. [RS-10 + RS-12]
Requisito de seguridad generado: RS-12	

Nota. Caso identificado durante el stress test. Elaboración propia.

Tabla 24
CA-13 — Exfiltración Encubierta Multi-Vector (IDOR + API Scraping Correlacionado) ★ NUEVO

Riesgo: ALTO | Probabilidad: Alta | Impacto: Alto	
Atacante	Periodista técnico con token ciudadano y scripts Python.
Objetivo	Descargar informes internos no publicados para obtener ventaja política antes de su publicación oficial.
Acciones del atacante	1. Obtiene token ciudadano legítimo; enumera IDs en /api/reportes. 2. Descubre que /api/reportes?estado=borrador no verifica el rol del solicitante. 3. Descarga 1–3 reportes por minuto (bajo el umbral de RS-04) alternando endpoints. 4. Combina datos internos con datos públicos para identificar contratos bajo revisión. 5. Toda la actividad aparece legítima en el SIEM: ciudadano accediendo a documentos normalmente.
Impacto	**Filtración de auditorías pre-publicación sin disparar ninguna alerta. CA-06 + CA-09 combinados son invisibles; el atacante obtiene ventaja informativa política antes que el público.**
Gap identificado	**CA-06 y CA-09 se modelaron como amenazas independientes. El SIEM (RS-10) monitorea señales individuales pero no correlaciona multi-vector. Un atacante bajo cada umbral individual no es detectado.**
Mitigaciones	✓ Control de acceso por estado: borradores solo para Auditor/Admin. [RS-13] ✓ Correlación multi-vector SIEM: mismo token, múltiples endpoints sensibles en 30 min. [RS-13] ✓ Baseline: alerta si token ciudadano accede a >10 documentos únicos/hora. [RS-13] ✓ Auditoría diferenciada: público vs. en revisión interna. [RS-13]
Requisito de seguridad generado: RS-13	

Nota. Caso identificado durante el stress test. Elaboración propia.

8. Defensa en Profundidad — Gaps y Nuevos Requisitos

Los requisitos RS-01 a RS-10 cubren el **77% de los vectores** identificados. Los tres gaps críticos exigen nuevos requisitos antes del despliegue.

8.1 Gaps Encontrados y Requisitos Generados

Tabla 25
Gaps encontrados y requisitos generados

ID	Tipo	Requisito nuevo	Gap que cubre	Descripción técnica
RS-11	**Funcional**	**Validación Estricta JWT**	RS-05 RBAC sin validación de firma → CA-11	jwt.verify() con { algorithms:['HS256'] }. Prohíbe jwt.decode(). HTTP 401 ante alg:'none' o confusion attacks.
RS-12	**Funcional**	**Atomicidad Aprobación Dual**	RS-03/RS-06 sin control de concurrencia → CA-12	SELECT FOR UPDATE + idempotency key + verificación de IDs distintos antes del commit.
RS-13	**No Funcional**	**Correlación Multi-Vector SIEM**	RS-10 SIEM individual → CA-13 invisible	Correlación por token en ventana 30 min. Baseline: alerta >10 documentos/hora por ciudadano.

Nota. Elaboración propia.

8.2 Mapa de Cobertura RS → CA

Tabla 26
Mapa de cobertura de los requisitos RS sobre los casos de abuso

Requisito	Casos cubiertos (original)	Casos nuevos cubiertos	Cobertura
RS-01 (MFA)	CA-05, CA-07	—	**90%**
RS-03 (Log inmutable)	CA-01, CA-08	CA-12 (parcial)	**70% — gap parcial**
RS-04 (Anti-DDoS)	CA-02, CA-09	CA-13 (parcial)	**75% — gap parcial**
RS-05 (RBAC)	CA-06	CA-11 sin RS-11	**50% — GAP CRÍTICO**
RS-10 (SIEM)	CA-01, CA-07, CA-08	CA-13 sin RS-13	**65% — GAP CRÍTICO**
RS-11 (JWT — NUEVO)	—	CA-11 (100%)	**100% ✓**
RS-12 (Locks — NUEVO)	—	CA-12 (100%)	**100% ✓**

Requisito	Casos cubiertos (original)	Casos nuevos cubiertos	Cobertura
RS-13 (SIEM+ — NUEVO)	—	CA-13 (100%)	**100% ✓**

Nota. Elaboración propia.

9. Escenario de Explotación — CA-11 en 6 Pasos

El sistema **tiene RBAC**, **tiene JWT**, **tiene roles bien definidos**. Pero hay una línea que lo anula: jwt.decode() en lugar de jwt.verify(). Esta es la historia de cómo un ciudadano se convierte en Administrador.

Tabla 27
Escenario de explotación de CA-11 en seis pasos

Paso	Descripción
Paso 1 — Reconocimiento	Crea cuenta ciudadana legítima, se autentica y captura el JWT con Burp Suite Proxy.
Paso 2 — Análisis del token	Decodifica payload: {"sub":"user_456","role":"citizen","municipio_id":"BOG01"}. El rol está en el payload sin binding a dispositivo o IP.
Paso 3 — Algorithm Confusion Attack	Cambia header de {"alg":"RS256"} a {"alg":"HS256"}. Obtiene clave pública de /api/.well-known/jwks.json (sin autenticación). La usa como secreto HMAC para firmar el token.
Paso 4 — Modificación del rol	Modifica payload: "role":"citizen" → "role":"admin". Genera nuevo token. Si el servidor usa jwt.decode(), acepta cualquier token bien formado.
Paso 5 — Acceso Admin obtenido	GET /api/admin/usuarios → HTTP 200: lista completa de auditores. El SIEM no alerta porque el token tiene estructura válida.
Paso 6 — Escalada de daño	Con emails reales de auditores lanza CA-05 (phishing dirigido). Alternativamente publica contratos falsos directamente desde el panel Admin.

Nota. Elaboración propia.

Resultado: Un ciudadano con conocimiento básico de JWT opera como Admin sin que el SIEM, el RBAC ni ningún otro control lo detecte.

10. Justificación de Costo-Riesgo

La gestión de riesgo implica invertir donde el impacto es mayor y el costo de mitigación es menor. Esta tabla argumenta cada decisión ante el CISO.

Tabla 28
Justificación de costo-riesgo por amenaza

Amenaza	Decisión	Justificación económica y técnica	Riesgo residual
CA-02 DDoS Electoral	**MITIGAR COMPLETAMENTE**	CDN Cloudflare: ~$200/mes. Costo de indisponibilidad electoral: pérdida de credibilidad + cobertura mediática + demandas. ROI claro.	Muy bajo con CDN
CA-03 SQL Injection	**MITIGAR COMPLETAMENTE**	Costo: cero (ORM ya en el stack). WAF incluido en Cloudflare. Impacto: destrucción irreversible del historial. Mitigación obligatoria.	Casi nulo con ORM
CA-11 JWT Manipulation	**MITIGAR — RS-11 (urgente)**	Costo: 2 horas de desarrollo (jwt.decode → jwt.verify + algoritmo fijo). Sin mitigación: cualquier ciudadano técnico se vuelve Admin.	Nulo tras RS-11
CA-12 Race Condition	**MITIGAR PARCIALMENTE — RS-12**	Locks pesimistas completos: ~3 semanas de rediseño. Mitigación intermedia: idempotency key (~2 días). Riesgo aceptado hasta v1.1.	Bajo-Medio hasta v1.1
CA-13 Multi-vector	**RIESGO ACEPTADO PARCIALMENTE**	Correlación avanzada SIEM: ~$500/mes adicionales. Mitigación básica RS-13 cubre el 80% del riesgo. Correlación avanzada en v2.0.	20% → monitoreo manual

Nota. Elaboración propia.

11. Refactorización Segura — Antes/Después y 3 Capas de Seguridad

La arquitectura segura encadena **3 middlewares**, que protegen cada endpoint sensible: autenticación, autorización y control de tasa.

11.1 Antes — Código vulnerable

```
// VULNERABLE: jwt.decode() no verifica firma ni algoritmo
app.get('/api/admin/contratos', async (req, res) => {
  const decoded = jwt.decode(token);         // acepta cualquier token bien
  formado
  if (decoded?.role === 'admin') {            // el atacante pone role:'admin'
  libremente
    res.json(await db.query('SELECT * FROM contratos'));
  }
});
```

11.2 API 1 — verifyToken: Autenticación con algoritmo fijo

Verifica firma y fija el algoritmo. Rechaza alg:'none' y algorithm confusion.

```
const verifyToken = (req, res, next) => {
  try {
    req.user = jwt.verify(token, process.env.JWT_SECRET, {
      algorithms: ['HS256'],   // fijo: rechaza 'none' y RS256->HS256
    });
    next();
  } catch (err) {
    return res.status(401).json({ error: 'Token inválido' });
  }
};
```

11.3 API 2 — authorizeRole: Autorización verificada en BD

Verifica el rol real en BD en cada petición, no confía solo en el contenido del token.

```
const authorizeRole = (...allowed) => async (req, res, next) => {
  const user = await db.users.findById(req.user.sub);   // rol real desde BD
  if (!user || !allowed.includes(user.role)) {
    return res.status(403).json({ error: 'Permisos insuficientes' });
  }
  req.dbUser = user; next();
};
```

11.4 API 3 — adminRateLimiter: Rate limiting + alerta SIEM

```
const adminRateLimiter = rateLimit({ windowMs: 60000, max: 30,
  handler: (req, res) => {
    siem.alert({ severity: 'HIGH', event: 'admin_rate_limit_exceeded', userId:
  req.user?.sub });
    res.status(429).json({ error: 'Límite excedido' });
  },
});
```

11.5 Endpoint final — las 3 capas encadenadas

```
app.get('/api/admin/contratos',
  adminRateLimiter,                    // API 3: límite + SIEM
  verifyToken,                         // API 1: firma + algoritmo fijo
  authorizeRole('admin', 'auditor'),  // API 2: rol verificado en BD
  async (req, res) => {
    const rows = await db.query(`SELECT * FROM contratos WHERE
  municipio_id=$1`,[req.dbUser.municipio_id]);
    res.json({ data: rows, total: rows.length });
  }
);
```

Tabla 29

Capas de seguridad de la refactorización y ataques que bloquean

Capa de seguridad	Qué valida	Ataque que bloquea	Costo de impl.
API 1 — verifyToken	Firma JWT + algoritmo fijo	CA-11: algorithm confusion, alg:none, tokens forjados	2 horas de desarrollo
API 2 — authorizeRole	Rol real en BD	CA-11: privilege escalation; tokens con roles ya eliminados	4 horas de desarrollo
API 3 — rateLimiter	Volumen + SIEM	CA-07: fuerza bruta; CA-09/CA-13: scraping y exfiltración	3 horas de desarrollo

Nota. Elaboración propia.